VULNSCAN — Automated Security Intelligence

Security Assessment & Vulnerability Audit Report

Generated on 2026-10-30 20:52:11 UTC | Platform: VulnScan v1.0

Target Project:	iCream Shop (Demonstration Target)	**Security Score:**	**5 / 100**
Target Scope:	http://127.0.0.1:8001	**Scan Mode:**	COMPREHENSIVE
Scan ID:	#3	**Gate Status:**	**FAIL (Critical findings present)**

1. Executive Summary

VulnScan completed a multi-vector security assessment across static source code (SAST), runtime endpoints (DAST), software dependencies (SCA), and credential exposure checks. The audit identified **12 total finding(s)** across the target scope. Immediate attention is recommended for Critical and High severity findings prior to production deployment.

CRITICAL	HIGH	MEDIUM	LOW	INFO	FIXED
1	**6**	**3**	**2**	**0**	**0**

2. Detailed Vulnerability Findings

#1 Unsafe SQL Query Construction via String Formatting — CRITICAL

Category:	SQL Injection (SQLi)	**CWE / CVE:**	CWE-89 CVE-2024-SQLI-01
Location:	app.py:343	**Source:**	SAST

Technical Evidence:

```
cursor.execute("SELECT id, name, flavor, price, description FROM products WHERE name LIKE ? OR flavor LIKE ?", (f"%{q}%", f"%{q}%"))
```

Technical Explanation: When untrusted variables are interpolated directly into SQL syntax, an attacker can manipulate query logic, bypass authentication, and access or dump sensitive database tables.

Remediation: Use parameterized queries or ORM prepared statements instead of raw string concatenation.

#2 Debug Mode Enabled in Web Framework Configuration — MEDIUM

Category:	Security Misconfiguration	**CWE / CVE:**	CWE-489 CVE-2024-MISC-06
Location:	app.py:14	**Source:**	SAST

Technical Evidence:

```
allow_origins=["*"],
```

Technical Explanation: Active debug mode exposes interactive tracebacks, environment secrets, and diagnostic consoles to attackers.

Remediation: Disable debug mode in production (DEBUG = False) and restrict CORS origins to trusted domains.

#3 Exposed Secret: Hardcoded JWT Secret / Token Key — HIGH

Category:	Hardcoded Secrets	**CWE / CVE:**	CWE-798
Location:	app.py:25	**Source:**	SECRETS

Technical Evidence:

```
JWT_SECR****************************************456"
```

Technical Explanation: Credentials committed directly to source control can be discovered by unauthorized parties or extracted from client bundles.

Remediation: Remove credential from source code immediately, revoke/rotate the compromised secret, and use environment variables or a Secret Manager.

#4 Vulnerable Dependency: requests (2.28.1) - Requests Proxy-Authorization Header Information Disclosure — HIGH

Category:	Vulnerable Dependencies	**CWE / CVE:**	CWE-200 CVE-2023-32681
Location:	requirements.txt:3	**Source:**	SCA

Technical Evidence:

```
requests==2.28.1
```

Technical Explanation: The installed version '2.28.1' of requests is below safe release 2.31.0.

Remediation: Upgrade requests to at least version 2.31.0 in requirements.txt.

#5 Vulnerable Dependency: urllib3 (1.26.15) - urllib3 Request Body not cleared after HTTP redirect — HIGH

Category:	Vulnerable Dependencies	**CWE / CVE:**	CWE-444 CVE-2023-45803
Location:	requirements.txt:4	**Source:**	SCA

Technical Evidence:

```
urllib3==1.26.15
```

Technical Explanation: The installed version '1.26.15' of urllib3 is below safe release 2.0.7.

Remediation: Upgrade urllib3 to at least version 2.0.7 in requirements.txt.

#6 Vulnerable Dependency: cryptography (40.0.1) - cryptography NULL pointer dereference in PKCS7 parsing — HIGH

Category:	Vulnerable Dependencies	**CWE / CVE:**	CWE-476 CVE-2023-49083
Location:	requirements.txt:5	**Source:**	SCA

Technical Evidence:

```
cryptography==40.0.1
```

Technical Explanation: The installed version '40.0.1' of cryptography is below safe release 41.0.6.

Remediation: Upgrade cryptography to at least version 41.0.6 in requirements.txt.

#7 Missing Content-Security-Policy (CSP) Header — MEDIUM

Category:	Security Misconfiguration	**CWE / CVE:**	CWE-1021
Location:	http://127.0.0.1:8001:	**Source:**	DAST

Technical Evidence:

```
HTTP Status: 200, Headers present: date, server, content-length, content-type
```

Technical Explanation: Content-Security-Policy restricts resources (such as scripts, images, stylesheets) that the browser is allowed to load for a given page.

Remediation: Implement a strict Content-Security-Policy header (e.g. default-src 'self').

#8 Missing X-Frame-Options (Clickjacking Risk) — MEDIUM

Category:	Security Misconfiguration	**CWE / CVE:**	CWE-1021
Location:	http://127.0.0.1:8001:	**Source:**	DAST

Technical Evidence:

```
X-Frame-Options header not found in server response.
```

Technical Explanation: Attackers can render the application within a transparent frame on a malicious page to trick users into triggering unintended actions.

Remediation: Add 'X-Frame-Options: DENY' or 'SAMEORIGIN' to all HTTP responses.

#9 Missing X-Content-Type-Options Header — LOW

Category:	Security Misconfiguration	**CWE / CVE:**	CWE-16
Location:	http://127.0.0.1:8001:	**Source:**	DAST

Technical Evidence:

```
Header X-Content-Type-Options missing
```

Technical Explanation: If a browser interprets a non-executable file as executable script, it can lead to script execution vulnerabilities.

Remediation: Send 'X-Content-Type-Options: nosniff' header.

#10 Information Disclosure: Server Version Header (uvicorn) — LOW

Category:	Sensitive Data Exposure	**CWE / CVE:**	CWE-200
Location:	http://127.0.0.1:8001:	**Source:**	DAST

Technical Evidence:

```
Server: uvicorn
```

Technical Explanation: Detailed banner exposure assists adversaries in fingerprinting known CVEs for targeted exploitation.

Remediation: Suppress or mask the Server header in web server configuration.

#11 Active Reflected Cross-Site Scripting (XSS) in Search Parameter — HIGH

Category:	Cross-Site Scripting (XSS)	**CWE / CVE:**	CWE-79 CVE-2024-XSS-DAST
Location:	http://127.0.0.1:8001/search?q=icecream:	**Source:**	DAST

Technical Evidence:

```
Reflected unencoded payload in HTTP response: ...vulnscan_test_xss_probe_...
```

Technical Explanation: A non-destructive test string containing HTML tags was returned unescaped in the document DOM.

Remediation: Contextually escape all parameters rendered into HTML templates.

#12 Broken Access Control: Publicly Accessible Admin Dashboard — HIGH

Category:	Broken Access Control / IDOR	**CWE / CVE:**	CWE-284
Location:	http://127.0.0.1:8001/admin:	**Source:**	DAST

Technical Evidence:

```
HTTP Status: 200 OK at administrative endpoint without credentials
```

Technical Explanation: Unauthenticated HTTP requests can access the administrative interface directly.

Remediation: Enforce role-based access control (RBAC) middleware on all /admin routes.

---

3. DevSecOps Deployment Gate & Next Steps

Deployment Policy Enforcement:

• Critical and High severity findings must be resolved and verified before staging deployment.
• Use VulnScan's AI Security Assistant to review contextual code patches.
• Execute Fix Verification Rescan to mark resolved items and unblock the CI/CD pipeline.